

## Task 1: Security Measures Used by PhonePe

| No. | Security Measure                | How It Protects Users                                                                                        |
|-----|---------------------------------|--------------------------------------------------------------------------------------------------------------|
| 1.  | Two-Factor Authentication (2FA) | Adds an additional authentication layer so that knowing a password alone is not enough to access an account. |
| 2.  | Encryption                      | Protects sensitive information while it is being transmitted and stored.                                     |
| 3.  | Access Controls                 | Ensures that users and employees can access only the information and resources they are authorized to use.   |
| 4.  | Transaction Monitoring          | Helps detect unusual or suspicious transactions and activities.                                              |
| 5.  | Security Logging and Monitoring | Records important security events so suspicious activities can be detected and investigated.                 |

## Task 2: Mapping Security Measures to the NIST Cybersecurity Framework

| Security Measure          | NIST CSF Category                                                 | Reason                                                                   |
|---------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------------|
| Two-Factor Authentication | Protect – Identity Management, Authentication, and Access Control | MFA helps verify user identity and prevents unauthorized account access. |
| Encryption                | Protect – Data Security                                           | Encryption protects sensitive information from unauthorized disclosure.  |
| Access Controls           | Protect – Identity Management,                                    | Access permissions ensure that only                                      |

|                                 |                                    |                                                                                        |
|---------------------------------|------------------------------------|----------------------------------------------------------------------------------------|
|                                 | Authentication, and Access Control | authorized users can access resources.                                                 |
| Transaction Monitoring          | Detect – Continuous Monitoring     | Monitoring can identify unusual or suspicious activity.                                |
| Security Logging and Monitoring | Detect – Continuous Monitoring     | Security logs provide information that can help identify potential security incidents. |

### Task 3: CIS Controls for a Food Delivery Application

#### Scenario

A new food delivery application wants to:

- Prevent unauthorized access.
- Protect payment information.
- Protect customer privacy.

Three useful CIS Controls are:

#### 1. CIS Control 6 – Access Control Management

This control focuses on managing user accounts and access privileges.

How it helps:

The application can use strong authentication, role-based access, and appropriate permissions. Employees should receive only the access required for their jobs.

#### 2. CIS Control 3 – Data Protection

This control focuses on protecting sensitive data throughout its lifecycle.

How it helps:

The food delivery application can identify sensitive information, restrict access to it, and use encryption to protect data.

#### 3. CIS Control 8 – Audit Log Management

This control focuses on collecting and managing logs of important activities.

How it helps:

The application can record login attempts, account changes, administrative actions, and security events. These logs can help identify suspicious activity.

Task 4: Comparison of NIST CSF, ISO 27001 and CIS Controls

| NIST Cybersecurity Framework                                                                                                          | ISO/IEC 27001                                                                                                    | CIS Controls                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| Risk-based framework: Helps organizations understand and manage cybersecurity risks.                                                  | Information security management system (ISMS): Provides a systematic approach for managing information security. | Prioritized security controls: Provides practical safeguards organizations can implement to reduce common cyber risks. |
| Flexible: Can be adapted to organizations of different sizes and industries.                                                          | International standard: Provides a globally recognized approach to information security management.              | Action-oriented: Focuses heavily on practical technical and administrative security measures.                          |
| Five core functions in the original structure: Identify, Protect, Detect, Respond and Recover; NIST CSF 2.0 adds the Govern function. | Certification: Organizations can undergo formal certification against ISO/IEC 27001.                             | Prioritized implementation: Controls can be implemented according to organizational risk and available resources.      |

Task 5: ISO 27001 Security Checklist for a Small E-Commerce Startup

AI-Generated Checklist

- ☐ Identify information assets and security risks – Create an inventory of important assets such as customer data, databases, servers, applications, and payment-related information, and assess the risks associated with them.
- ☐ Implement access control – Give employees access only to the systems and information required for their jobs, and review user permissions regularly.
- ☐ Protect customer and business data – Use appropriate encryption, secure backups, access restrictions, and secure data-handling procedures to protect sensitive information.
- ☐ Create security policies and procedures – Establish documented policies covering passwords, acceptable system use, incident reporting, remote access, data protection, and employee responsibilities.
- ☐ Conduct security monitoring and regular reviews – Monitor important security events, perform periodic risk assessments, review security controls, and improve them when weaknesses are identified.

#### My Comment

I agree with this checklist because it covers the major areas a small e-commerce startup needs to address. ISO 27001 is not only about installing technical security tools; it also involves risk management, policies, people, processes, and continual improvement.

For a small startup, I would prioritize risk assessment, access control, data protection, security policies, and continuous monitoring because these provide a strong foundation for protecting customer information and business systems.